

TryHackMe: Cupid's Secret Vault Write-up

Room Overview

The objective of this room is to explore the web application "Cupid's Secret Vault" and identify any hidden secrets or vulnerabilities.

Steps Taken

1. Initial Recon

2. Opened the main URL: `http://10.66.162.218:5000/cupids_secret_vault/`

3. Observed the HTML structure and design, including custom fonts and color gradients. Nothing immediately actionable on the landing page.

4. Directory Bruteforce

5. Used `ffuf` to discover hidden directories:

```
ffuf -u http://10.66.162.218:5000/cupids_secret_vault/FUZZ -w /usr/share/wordlists/dirb/common.txt
```

6. Found a directory called `/administrator` which led to an admin login page.

7. Admin Login Page

8. Navigated to: `http://10.66.162.218:5000/cupids_secret_vault/administrator`

9. Observed a login form requesting `username` and `password`. The page was styled with a `Georgia, serif` font and vibrant gradients.

10. Testing Methods

11. Attempted POST requests with curl to submit credentials:

```
curl -X POST -d 'username=admin&password=TEST' http://10.66.162.218:5000/cupids_secret_vault/administrator
```

12. Verified that invalid credentials returned an "Invalid credentials" message.

13. Observation

14. Noticed hints in the web application and headers suggesting that secrets could be hidden in static files such as `robots.txt`.

15. Robots.txt Check

16. Checked `robots.txt` for disallowed entries:

```
curl http://10.66.162.218:5000/robots.txt
```

17. Found paths that were disallowed to search engines, indicating hidden content worth exploring.

Lessons Learned

- Always perform directory and file enumeration on web applications.
- Check standard locations such as `/robots.txt` for hidden resources.
- Inspect HTML and headers carefully for subtle hints.
- Admin pages are often accessible through brute-force discovery even if login credentials are unknown.

Conclusion

The room provided hands-on experience in: - Web reconnaissance - Directory brute-forcing - Basic analysis of web pages - Using curl and ffuf for enumeration

This write-up excludes any sensitive content or flags, focusing solely on methodology and learning points.